# Technical Risk Treatment Lab Report

## Northbridge Services

### Technical Risk Treatment Lab - Risk Treatment and Control Validation Report

### 1. Management Summary

This report documents the risk-treatment approach for Northbridge Services, a fictional organisation whose internal document server exposes an unnecessary legacy endpoint and a web-published directory containing dummy files. The lab requires measurable risk treatment while preserving the approved web portal.

The treatment design applies four strategies.

**Avoidance** retires the unnecessary legacy endpoint.

**Mitigation** removes archive content from the web root, restricts filesystem permissions, disables directory listing, denies the retired archive URL and limits inbound HTTP access to the approved Kali test address.

**Transfer** evaluates a fictional managed-backup service while recognising that the organisation retains responsibilities for data, access and restoration testing.
**Acceptance** considers temporary retention of plain HTTP only on the isolated lab network with dummy data, a simulated owner, a 14-day expiry and defined escalation triggers.

## 2. Purpose

The purpose is to implement and validate preventive, detective and corrective controls, reassess the four risks, compare treatment strategies, estimate first-year costs and document residual risk, ownership and monitoring.

### Lab Design and Control Objectives

The baseline design intentionally creates two reachable services and a web-published archive. The target state preserves the approved Nginx portal and closes the unnecessary exposure.

| Control objective | Implementation | Validation requirement |
|---|---|---|
| Retire unnecessary service | Disable and stop grc-legacy.service | TCP 8080 no longer listening/open; Nginx on TCP 80 remains available |
| Remove archive publication | Move archive to /srv/grc-private; restrict permissions; explicitly deny /archive/ | /public/ returns HTTP 200; /archive/ and old dummy-file URL return HTTP 403 |
| Disable directory listing | Configure autoindex off | / returns HTTP 403 in this lab because no root index file exists; /public/ remains accessible |

| Control objective | Implementation | Validation requirement |
|---|---|---|
| Restrict network access | UFW default-deny inbound and allow TCP 80 only from approved Kali IP | Approved source receives portal; unapproved source is blocked and corroborated by UFW logs |
| Detect events | Nginx access/error logs and UFW/kernel firewall logs | Timestamped requests and relevant records correlate to test IDs |
| Recover portal content | Protected same-host archive backup, restore and SHA-256 check | Deleted test file is restored, hash matches and HTTP 200/content are verified |

## 3. Baseline Risk Register

**Scoring:** Risk score = Likelihood (1-5) x Impact (1-5). Bands: 1-4 Low; 5-9 Medium; 10-16 High; 17-25 Critical.

| ID / Asset | Threat event and weakness to verify | Initial rating (L x I = score) | Owner and baseline evidence |
|---|---|---|---|
| **R1 - Ubuntu host / network service** | An attacker uses the unnecessary legacy endpoint. The lab service is expected to listen on all interfaces on TCP 8080. | 4 x 4 = **16 High** | Server Administrator. baseline-ports.txt, baseline-legacy.txt and Ubuntu ss output. |
| **R2 - Dummy archive records** | An unauthorised user discovers or retrieves web-published files. /archive/ listing and the dummy file are expected to be reachable over HTTP. | 4 x 4 = **16 High** | Web/Application Owner. baseline-listing.txt and baseline-file.txt. |
| **R3 - Internal portal and host** | An unapproved source reaches a service that should be restricted. No effective source-IP restriction has yet been demonstrated. | 4 x 5 = **20 Critical** | Network/Security Administrator. baseline-ports.txt, baseline-web.txt, UFW and ss output. |
| **R4 - Approved portal content** | Portal content is lost and cannot be restored promptly. Backup and recovery capability has not yet been verified. | 3 x 4 = **12 High** | Service Owner. Baseline backup inventory and restore-evidence status. |

## 4. Avoidance - Retire the Legacy Workflow

### 4.1 Proposed change

Retire the unused grc-legacy.service endpoint on TCP 8080 while retaining the approved Nginx portal on TCP 80. This avoids the exposure associated with the retired workflow; it does not eliminate risk to the remaining host or web service.

# 5. Mitigation - Preventive Control Implementation

## 5.1 Remove archive publication and restrict access

The archive is moved out of the Nginx document root to /srv/grc-private/, with access restricted to root. The Nginx site configuration disables directory listing and explicitly denies the old archive URL.

Validation from Kali:

| Request | HTTP result |
|---|---|
| /public/ | 200 |
| /archive/ | 403 |
| /archive/dummy-records.txt | 403 |
| / | 403 |

Disabling directory listing alone is insufficient: it prevents a server from presenting an index of files, but a user who knows or guesses a direct file path may still request that file. Moving the archive outside the web root, restricting filesystem permissions and denying the old URL provide additional layers.

### 5.2 Restrict network access with UFW

The proposed firewall policy is:

- Default deny incoming traffic.
- Default allow outgoing traffic.
- Allow TCP port 80 only from the actual approved Kali isolated-network IP.
- Enable UFW logging.

| Test | Source | Lab result | Evidence to retain |
|---|---|---|---|
| Approved source | 192.168.0.27 | /public/ returns HTTP 200 | ufw status numbered, successful curl output and timestamp |
| Unapproved source | 192.168.0.26 | Connection is blocked / times out | Blocked curl output, source IP, timestamp, UFW rule output and corroborating firewall log |

## 6. Four Risk Treatment Strategies

| Strategy | Application in this lab | Decision / governance record |
|---|---|---|
| Avoidance | Retire the unused legacy endpoint and discontinue the workflow it supports. | Simulated change approval, service test, rollback plan and evidence that port 8080 is no longer exposed. |
| Mitigation | Move the archive outside the web root, restrict permissions, deny the old URL, disable directory listing, restrict inbound access with UFW, enable logging and test recovery. | Record actual implementation and validation evidence. Residual risk remains for the permitted portal and host. |
| Transfer | Evaluate a fictional managed-backup service at $120 setup plus $20/month. | A proposed service clause and responsibility split are included below. The organisation retains technical and governance duties. |
| Acceptance | Consider temporary plain HTTP only on the isolated network with dummy data. | Simulated risk owner, documented residual score, 14-day expiry, review date and triggers. Escalate rather than accept if the system leaves the lab boundary or processes real data. |

### 6.1 Transfer - managed-backup offer

**Fictional price:** $120 setup + $20 per month = $360 for the first 12 months.

**Provider duties proposed:** securely store and protect backup copies; operate the contracted backup service; monitor job completion; notify the customer of failed jobs and relevant security incidents within agreed times; support restoration requests; provide service availability and retention reporting; and preserve agreed evidence of backup and restore activity.

**Customer duties retained:** classify and select the data to be protected; configure and maintain source access; approve retention and recovery objectives; protect credentials and encryption keys; review access and job reports; test restoration at an agreed frequency; confirm recovered data integrity; and maintain an independent recovery and incident-response process.

**Required contract / evidence conditions:** define scope, retention, encryption, access, data location, availability, incident notification, restoration support, evidence retention, service exclusions, subcontractors and termination/export arrangements. Require periodic restoration tests and retain reports showing the test date, scope, result and integrity check.

**Proposed service clause:**

> The Provider shall perform and monitor backups of the Customer-approved data set in accordance with the agreed schedule and retention period, protect backup copies using the agreed security controls, notify the Customer of failed backup jobs and reportable security incidents within the agreed notification window, and provide restoration support on request. The Provider shall supply dated backup and restoration evidence for the contracted service. The Customer remains responsible for data classification, source-system access, user permissions, key management where applicable, validation of restored data and approval of recovery objectives. The parties shall conduct and document a restoration test at least. This service does not guarantee recovery from events outside the contracted scope or remove the Customer's responsibility to maintain continuity arrangements.

## 6.2 Acceptance - temporary plain HTTP

| Field | Proposed record |
|---|---|
| Risk | R5 - Clear-text HTTP on the isolated training network |
| Risk owner | Northbridge Services Service Owner |
| Rationale | The lab is isolated, contains dummy data only and is not reachable from the public Internet. HTTP remains a risk because traffic is not encrypted. |
| Expiry | 14 calendar days after the simulated acceptance date: |
| Mandatory treatment | Implement and validate TLS (Option C) before any real data, external connectivity or broader use. |
| Immediate triggers for escalation/rejection | Real data is introduced; network becomes bridged/public; the service is accessed from a broader network; the host is repurposed; or the 14-day expiry is reached without TLS validation. |

# 7. Cost Comparison and Financial Analysis

## 7.1 First-year option costs

| Option | First-year calculation | First-year total |
|---|---|---|
| **A - Hardening** | (4 hours x $25) + $50 annual maintenance | **$150** |
| **B - Managed backup** | $120 setup + ($20 x 12 months) | **$360** |
| **C - TLS deployment** | (3 hours x $25) + $25 annual maintenance | **$100** |
| **A + B** | $150 + $360 | **$510** |
| **A + C** | $150 + $100 | **$250** |
| **B + C** | $360 + $100 | **$460** |
| **A + B + C** | $150 + $360 + $100 | **$610** |

**Recommended combination: A + B + C ($610 first year).** Option A addresses the known service and web-exposure weaknesses; Option B adds an off-host backup service with contractual restoration duties; Option C removes the temporary clear-text HTTP condition before any wider or real-data use.

### Illustrative annual loss expectancy (ALE) scenario for Option B

- Annual occurrence rate (ARO): 0.2 events per year.
- Loss per event before control: $5,000.
- Loss per event after a tested recovery control: $1,000.
- Option B first-year cost: $120 setup + ($20 x 12) = $360.

| Calculation | Formula | Result |
|---|---|---|
| Baseline ALE | 0.2 x $5,000 | **$1,000/year** |
| Residual ALE | 0.2 x $1,000 | **$200/year** |
| Annual benefit | $1,000 - $200 | **$800/year** |
| First-year net benefit | $800 - $360 | **$440** |

## 8. Residual Risk Assessment

| Risk | Proposed residual rating | Evidence required before confirming | Owner / review trigger |
|---|---|---|---|
| **R1 - Legacy endpoint** | L1 x I4 = **4 Low** | Service status, ss output, post-treatment Nmap and failed legacy request. | Server Administrator; review after service/configuration changes or unexpected port detection. |
| **R2 - Exposed archive** | L1 x I4 = **4 Low** | Filesystem permissions, Nginx configuration, and 403 responses for directory and direct-file requests. | Web/Application Owner; review after content or web-root changes. |
| **R3 - Unauthorised network access** | L2 x I5 = **10 High** | UFW numbered rules, approved-source 200 response, blocked-source test and matching firewall log. | Network/Security Administrator; review after firewall or network changes. |
| **R4 - Portal content loss** | L2 x I4 = **8 Medium** | Backup listing, restore test, matching SHA-256, observed recovery time and managed-service evidence if procured. | Service Owner; review after restore tests, backup failures or material changes. |

## 9. Monitoring and Operational Handover

The following checks are proposed ongoing monitoring, not measurements collected by the lab unless actual monitoring evidence is attached.

| Check and owner | Frequency / threshold | Escalation |
|---|---|---|
| **Approved portal availability** - Service Owner / Operations | Daily check; monthly review. Expected HTTP response and approved content; investigate any failed check. | Open an incident, notify the service owner and invoke recovery if the outage persists. |
| **Unexpected open ports** - Security / Server Administrator | Weekly scan and after configuration changes. Only approved ports present; TCP 8080 remains closed. | Investigate immediately, preserve scan/log evidence and disable unauthorised service through change control. |
| **Backup and recovery success** - Backup Owner / Service Owner | Daily job review; monthly restoration test or approved schedule. Backup succeeds and restoration passes integrity verification. | Escalate failed jobs, initiate recovery and track corrective action to closure. |
| **Legacy-service configuration drift** - Server Administrator | Weekly and after patch/restart/change. grc-legacy.service remains disabled/inactive; no listener on 8080. | Investigate drift, reapply approved treatment and record the change. |
| **Firewall/access-rule integrity** - Network/Security Administrator | Weekly and after network changes. Only approved HTTP source rule exists; blocked-source test has corroborating evidence. | Investigate broad rules, missing logs or unexpected permitted sources. |

## 10. Conclusion

The treatment approach combines avoidance, mitigation, transfer and conditional acceptance while preserving the approved internal portal.